Security & Privacy Disclosure, Final Report

Tuya Smart (com.tuya.smart)

A Chinese-operated smart-home app declares 27 Android Health Connect permissions including blood pressure and heart rate, ships a platform API key and Google/Firebase keys in every copy, and drew no reply of any kind across ten messages over 74 days and a 19-day-overdue embargo

PUBLIC DISCLOSURE, 17 OCTOBER 2026, EMBARGO REACHED 28 SEPTEMBER 2026, THREE FINDINGS WITHOUT ANY RESPONSE

Target	Tuya Inc. (Hangzhou, PRC; NYSE: TUYA), operating through the PRC entity named in the initial disclosure as Hangzhou Tuya Information Technology Co., Ltd.
Package	com.tuya.smart v7.8.6 (versionCode 840), 172.7 MB, 123,495 smali classes
Platform Audited	Android, static analysis of the production APK (apktool, smali and resource review)
Initial Disclosure (R1)	2026-06-30 (REF COM.TUYA.SMART)
Disclosure / Embargo Date	2026-09-28
Report Published	2026-10-17
Overall Severity	CRITICAL
Findings	3 (1 Critical, 2 High), the three findings disclosed to the operator in the initial disclosure
Correspondence	10 messages sent by RFI-IRFOS over 74 days (2026-06-30 to 2026-09-12); zero reply of any kind, zero automated acknowledgment. privacy@tuya.com never returned a delivery failure; security@tuya.com and eu-support@tuya.com rejected delivery
Authorities CC'd	Austrian Datenschutzbehoerde (DSB), visible CC on 5 messages from 2026-07-23; European Data Protection Supervisor (EDPS), visible CC on 4 messages from 2026-08-04

security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Operator Context 4

3 Architecture & Data Flow 5

4 Findings 5

4.1 C1: Tuya IoT Platform app key hardcoded in every distributed copy 5

4.2 C2: 27 Android Health Connect permissions, including blood pressure, heart rate, and oxygen saturation, on a smart-home app run by a PRC entity 6

4.3 C3: Two Google/Firebase API keys and a Firebase Realtime Database URL hard-coded in resources and code 7

5 Impact Analysis 7

6 The Complete Chain: Ten Messages, Three Findings, Zero Replies 8

7 Data Protection – Article by Article 8

8 Regulatory & Legal Landscape 9

9 Indicators of Compromise 9

10 Disclosure Timeline & Outcome 10

11 Residual Risk & Recommendations 10

Executive Summary

Tuya Smart (com.tuya.smart, v7.8.6) is the flagship smart-home control app of Tuya Inc. (Hangzhou, PRC; NYSE: TUYA). A root-level static analysis of the production Android binary produced three findings, which RFI-IRFOS disclosed to the operator on 30 June 2026: the app declares 27 Android Health Connect permissions including READ access to blood pressure, heart rate, and blood-oxygen saturation (C2); the Tuya IoT Platform app key is hardcoded in every distributed copy (C1); and two Google/Firebase API keys plus a Firebase Realtime Database URL are hardcoded in resources and code (C3).

The operator is a PRC entity. The initial disclosure asked three written questions: which Art. 44 to 49 GDPR transfer mechanism covers Art. 9 health data of EU users, what the hardcoded platform key authenticates and whether it was rotated, and whether the competent supervisory authority was notified under Art. 33. None of the three was answered.

RFI-IRFOS sent ten messages over 74 days. privacy@tuya.com is the only address that accepted delivery. security@tuya.com rejected external senders by server policy and eu-support@tuya.com rejected delivery with a 550 error. No human reply and no automated acknowledgment arrived at any time. The stated embargo of 28 September 2026 passed without response, and this report publishes 19 days later.

ID	Severity	Title
C1	HIGH	Tuya IoT Platform app key hardcoded in every distributed copy
C2	CRITICAL	27 Android Health Connect permissions, including blood pressure, heart rate, and oxygen saturation, on a smart-home app run by a PRC entity
C3	HIGH	Two Google/Firebase API keys and a Firebase Realtime Database URL hardcoded in resources and code

Subject & Operator Context

Tuya Smart is the flagship consumer control app on Tuya Inc.'s smart-home platform, built on the Tuya/Thing SDK stack, and controls lighting, thermostats, cameras, door locks, and climate systems in European households. The operator is Tuya Inc., headquartered in Hangzhou, China and listed on the NYSE (TUYA). The initial disclosure identified the operating PRC entity as Hangzhou Tuya Information Technology Co., Ltd. A PRC-headquartered operator is subject to Article 7 of the PRC National Intelligence Law (2017), under which organizations and citizens are required to support, assist, and cooperate with state intelligence work. RFI-IRFOS assessed the sibling app com.tuya.smartlife separately under REF SMART LIFE-2026-R1-001, with structurally overlapping findings.

Architecture & Data Flow

The 172.7 MB APK holds 123,495 smali classes and is built on the Thing SDK namespace (com.thingclips). The platform app key is compiled into BuildConfig, the Google/Firebase identifiers are carried in res/values/strings.xml and in the ThingNGConfig class, and Android Health Connect permissions are declared in the manifest. This report documents what the shipped artifact contains. Server-side processing, retention, and the physical location of the datacenter serving a given EU user are outside what a static analysis can observe, and are the subject of the questions the operator did not answer.

Findings

C1: Tuya IoT Platform app key hardcoded in every distributed copy

MEDIUM, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N, 6.9, RFI-IRFOS blast-radius escalation: raised from MEDIUM/6.9 to HIGH because the key ships in every copy of a consumer app that controls cameras and door locks, and the operator never answered what it authenticates

```
.field public static final THING_SMART_APPKEY:Ljava/lang/String; = "3cxxt3au..."
[full value disclosed privately to Tuya in R1]
```

Impact: The Tuya IoT Platform app key (THING_SMART_APPKEY) is a compile-time constant in smali_classes12/com/thingclips/sample/BuildConfig.smali and is present in every copy of com.tuya.smart v7.8.6 distributed on Google Play. Anyone with apktool can read it in under a minute. The initial disclosure rated this finding CRITICAL. Under the CVSS v4.0 scoring applied to all RFI-IRFOS final reports it scores 6.9, because an app key identifies the client and the paired secret is not part of this finding; RFI-IRFOS therefore reports it as HIGH with the escalation stated above. Whether the key was rotated, and which backend services it authenticates, are the open questions the operator left unanswered. Art. 32(1)(b) and Art. 25 place the burden of showing appropriate technical measures on the operator. RFI-IRFOS blast-radius escalation: raised from MEDIUM/6.9 to HIGH because the key ships in every copy of a consumer app that controls cameras and door locks, and the operator never answered what it authenticates.

C2: 27 Android Health Connect permissions, including blood pressure, heart rate, and oxygen saturation, on a smart-home app run by a PRC entity

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N, 7.1, RFI-IRFOS blast-radius escalation: raised from HIGH/7.1 to CRITICAL because special-category health data of EU households is in scope, the operator is subject to PRC National Intelligence Law Art. 7, and no Art. 44 to 49 transfer mechanism was disclosed or provided when asked in writing

```
android.permission.health.READ_BLOOD_PRESSURE   android.permission.health.
    WRITE_BLOOD_PRESSURE
android.permission.health.READ_HEART_RATE   android.permission.health.WRITE_HEART_RATE
android.permission.health.READ_OXYGEN_SATURATION   android.permission.health.
    WRITE_OXYGEN_SATURATION
android.permission.health.READ_SLEEP   android.permission.health.WRITE_SLEEP
android.permission.health.READ_STEPS   android.permission.health.WRITE_STEPS
android.permission.health.WRITE_BODY_FAT   android.permission.health.
    WRITE_BODY_TEMPERATURE
android.permission.health.WRITE_BONE_MASS   android.permission.health.
    WRITE_BASAL_METABOLIC_RATE
android.permission.USE_BIOMETRIC   android.permission.USE_FINGERPRINT
(27 distinct health and biometric permissions in total)
```

Impact: The manifest declares 27 Android Health Connect and biometric permissions, among them READ and WRITE for blood pressure, heart rate, and oxygen saturation, READ and WRITE for sleep and steps, and WRITE for body fat, body temperature, bone mass, lean body mass, weight, height, and basal metabolic rate, plus USE_BIOMETRIC and USE_FINGERPRINT. Blood pressure, heart rate, oxygen saturation, and sleep are data concerning health under Art. 9(1). The permissions are declared in the manifest; this report asserts that the app is configured to request this data, that the operator is a PRC entity, and that the privacy policy and in-app consent flow reviewed on 30 June 2026 disclosed no Art. 44 to 49 transfer mechanism. It does not assert that any individual user's health data reached a Chinese server. For an app whose stated purpose is device control, the scope also presses on Art. 5(1)(c) minimisation and raises the Art. 35 DPIA question. RFI-IRFOS blast-radius escalation: raised from HIGH/7.1 to CRITICAL because special-category health data of EU households is in scope, the operator is subject to PRC National Intelligence Law Art. 7, and no Art. 44 to 49 transfer mechanism was disclosed or provided when asked in writing.

C3: Two Google/Firebase API keys and a Firebase Realtime Database URL hardcoded in resources and code

MEDIUM, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N, 6.9, RFI-IRFOS blast-radius escalation: raised from MEDIUM/6.9 to HIGH because the keys sit in every distributed copy of a household-control app and the operator did not respond when asked in writing whether they are scoped

```
google_api_key: AIzaSyDQ5r...
google_crash_reporting_api_key: AIzaSyDQ5r...
google_maps_key: AIzaSyANRe...
firebase_database_url: https://tuyasmart-7d54f.firebaseio.com
[full values disclosed privately to Tuya in R1]
```

Impact: res/values/strings.xml carries google_api_key and google_crash_reporting_api_key (the same value), a separate google_maps_key, and a firebase_database_url; ThingNGConfig.smali repeats the maps key. The initial disclosure rated this finding CRITICAL; at CVSS v4.0 6.9 it is reported as HIGH with the escalation stated above. Google API keys are identifiers and not secrets by themselves, but an unrestricted key exposes the project to quota and billing exhaustion, and a misconfigured database rule becomes a direct exposure path. Under Art. 5(2) and Art. 32 the burden to show that each key is scoped lies with the operator. RFI-IRFOS blast-radius escalation: raised from MEDIUM/6.9 to HIGH because the keys sit in every distributed copy of a household-control app and the operator did not respond when asked in writing whether they are scoped.

Impact Analysis

C2 is the finding with human weight: a smart-home app asks for the permission set of a health tracker, in the hands of an operator under PRC intelligence-law jurisdiction, with no transfer mechanism disclosed. C1 and C3 are the security-engineering findings that sit under it: a platform app key and Google/Firebase identifiers that ship in every copy and whose scope the operator never described. What ties the three together procedurally is the correspondence record: ten messages, one functioning address, and no reply.

The Complete Chain: Ten Messages, Three Findings, Zero Replies

Step 1, disclosure: On 30 June 2026 RFI-IRFOS sends the three findings and three written questions to security@tuya.com and privacy@tuya.com, with eu-support@tuya.com in CC, stating a response deadline of 14 July 2026 and an embargo of 28 September 2026.

Step 2, delivery failures: security@tuya.com rejects the message because the group only accepts internal senders, and eu-support@tuya.com rejects it with a 550 5.4.1 error. privacy@tuya.com returns no failure.

Step 3, nine follow-ups: RFI-IRFOS writes again on 6 July, 17 July, 23 July, 27 July, 4 August, 15 August, 24 August, 31 August, and 12 September 2026. security@tuya.com rejects the 6 July and 27 July messages again. No reply and no acknowledgment arrives at any point.

Step 4, embargo: The embargo, stated once and never revised, passes on 28 September 2026.

Step 5, publication: This report publishes on 17 October 2026, 19 days after the embargo date.

Data Protection – Article by Article

Art. 9(1), 9(2)(a) GDPR: C2's 27 health and biometric permissions require explicit consent or another Art. 9(2) basis for any health data actually processed.

Art. 44 to 49 GDPR: C2's PRC operator and the transfer mechanism that the operator was asked to name and did not.

Art. 5(1)(c) and Art. 35 GDPR: C2's scope against the stated purpose of the app, and the DPIA question for large-scale special-category processing.

Art. 32(1)(b) and Art. 25 GDPR: C1's hardcoded platform key and C3's hardcoded Google/Firebase identifiers.

Art. 5(2) GDPR: accountability for showing that each key is scoped rests with the operator.

Art. 33 GDPR: the third written question asked whether the supervisory authority was notified; it was not answered.

Regulatory & Legal Landscape

The binary shows no EU main establishment and no Art. 27 representative, so no one-stop-shop mechanism can be derived from the artifact. RFI-IRFOS's reporting authority for this case is the Austrian Datenschutzbehoerde (DSB), visible in CC from 23 July 2026, together with the European Data Protection Supervisor (EDPS), visible in CC from 4 August 2026.

Fine exposure: Art. 83(5) GDPR applies to the Art. 9 and Art. 44 to 49 issues in C2, up to EUR 20,000,000 or 4% of total worldwide annual turnover. Art. 83(4) applies to the Art. 32 and Art. 25 issues in C1 and C3, up to EUR 10,000,000 or 2%. A NYSE-listed operator that received ten written disclosures and did not acknowledge one is itself a fact a regulator can weigh next to the technical findings.

Indicators of Compromise

The following identifiers were extracted from the production APK by static analysis only. No Tuya, Alibaba, or Google servers, accounts, or infrastructure were probed.

```
Package: com.tuya.smart v7.8.6 (versionCode 840), 172.7 MB, 123,495 smali classes

C1 -- smali_classes12/com/thingclips/sample/BuildConfig.smali: THING_SMART_APPKEY (3
    cxxt3au..., truncated)

C2 -- AndroidManifest.xml: 27 android.permission.health.* and biometric permissions (
    see excerpt above)

C3 -- res/values/strings.xml: google_api_key, google_crash_reporting_api_key (
    AIzaSyDQ5r...), google_maps_key (AIzaSyANRe...), firebase_database_url tuyasmart-7
    d54f.firebaseio.com; smali_classes12/com/smart/app/ThingNGConfig.smali
```

Disclosure Timeline & Outcome

2026-06-30 Initial disclosure (R1) sent to security@tuya.com and privacy@tuya.com, CC eu-support@tuya.com. Response deadline 2026-07-14, embargo 2026-09-28. security@tuya.com and eu-support@tuya.com reject delivery. REF COM.TUYA.SMART.

2026-07-06 Follow-up to security@tuya.com and privacy@tuya.com, CC eu-support@tuya.com. security@tuya.com and eu-support@tuya.com reject delivery again.

2026-07-17 Follow-up to privacy@tuya.com.

2026-07-23 Follow-up to privacy@tuya.com, CC Austrian DSB.

2026-07-27 Follow-up to security@tuya.com and privacy@tuya.com. security@tuya.com rejects delivery.

2026-08-04, 2026-08-15, 2026-08-24, 2026-08-31 Follow-ups to privacy@tuya.com, CC Austrian DSB and EDPS.

2026-09-12 Tenth message to privacy@tuya.com, 74 days after the original disclosure, with a new deadline of 2026-09-19. No further correspondence follows.

2026-09-28 Embargo date reached, as stated on 2026-06-30 and never revised. Correspondence record: ten RFI-IRFOS messages, zero replies of any kind.

2026-10-17 This report published, 19 days after the embargo date.

Residual Risk & Recommendations

C1 – Immediate: state which services the platform app key authenticates, rotate it, and document the scope of access it grants.

C2 – Immediate: document the Art. 9(2) basis, the Art. 35 DPIA, and the Art. 44 to 49 transfer mechanism for the Health Connect permission scope, or remove permissions with no demonstrated device-control purpose.

C3 – Near-term: restrict all Google/Firebase keys by package name, SHA-1 signature, and API, and review the Realtime Database rules for tuyasmart-7d54f.

Across all findings: designate an Art. 27 EU representative and establish a monitored intake path for security and data-protection disclosures that produces at minimum an acknowledgment, which ten messages over 74 days failed to produce.

This report covers v7.8.6 as audited on 2026-06-30. Later versions of the app are subject to their own review.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from static analysis of the published application using publicly available tooling. No Tuya, Alibaba, or Google servers, accounts, or infrastructure were probed. Technical evidence is archived under chain of custody and will be provided to regulatory authorities on request. Research conducted under ISO/IEC 29147, the freedom of scientific research (Art. 17 StGG) and GDPR Art. 89. REF COM.TUYA.SMART.